

PASSIVE VULNERABILITY ASSESSMENT OF ALTORO MUTUAL

Security Assessment & Risk Analysis Report

Submitted as Part of the
Future Interns Cyber Security Internship Program

Field	Details
Prepared By	Safal Kumar Singh
Internship Domain	Cyber Security
Organization	Future Interns
Assessment Type	Passive / Non-Intrusive Vulnerability Assessment
Target Application	Altoro Mutual (http://demo.testfire.net)
Report Date	May 2026

Table of Contents

1. Executive Summary
2. Scope of Assessment
3. Assessment Methodology
4. Reconnaissance and Service Enumeration
5. Security Header Analysis
6. SSL/TLS Configuration Review
7. OWASP ZAP Passive Analysis
8. Detailed Vulnerability Findings
9. Risk Classification Matrix
10. Security Posture Assessment
11. Remediation Recommendations
12. Conclusion
13. Disclaimer

1. Executive Summary

This report presents the findings of a passive and non-intrusive vulnerability assessment conducted on the intentionally vulnerable web application Altoro Mutual hosted at <http://demo.testfire.net>.

The assessment was performed as part of the Future Interns Cyber Security Internship Program and strictly adhered to ethical and educational security testing practices. No exploitation attempts or destructive testing methods were employed during the assessment.

The primary objective was to identify publicly observable security weaknesses and misconfigurations using passive reconnaissance and vulnerability assessment techniques.

Assessment Objectives

- Identify observable security weaknesses using passive techniques.
- Analyse HTTP security headers and web application responses.
- Review SSL/TLS configurations and encryption support.
- Perform reconnaissance and service enumeration.
- Provide remediation recommendations aligned with industry best practices and OWASP guidelines.

Tools Utilized

Tool	Purpose
Nmap	Port and service enumeration
OWASP ZAP	Passive vulnerability scanning
cURL	HTTP header inspection
SSLScan	SSL/TLS configuration analysis
Browser Developer Tools	Client-side analysis

2. Scope of Assessment

Assessment Details

Parameter	Description
Target URL	http://demo.testfire.net
Assessment Type	Passive Vulnerability Assessment
Application Type	Deliberately Vulnerable Banking Application
Assessment Period	May 2026

In-Scope Activities

- HTTP and HTTPS traffic observation
- Security header analysis
- SSL/TLS configuration review
- Passive vulnerability scanning using OWASP ZAP
- Network reconnaissance and service discovery

Out-of-Scope Activities

- Exploitation attempts
- SQL Injection testing
- Authentication bypass attacks
- Brute-force testing
- Denial-of-Service (DoS) attacks
- Any destructive security testing

3. Assessment Methodology

A structured security assessment methodology was adopted to ensure comprehensive yet non-intrusive analysis.

Phase 1: Reconnaissance

Initial reconnaissance activities were performed to identify publicly accessible services, application endpoints, and externally visible attack surfaces.

Phase 2: Service Enumeration

Network reconnaissance was conducted using Nmap to identify open ports and discover running services.

Phase 3: Passive Web Application Analysis

OWASP ZAP was configured in passive scan mode to observe HTTP responses and identify security misconfigurations without actively attacking the application.

Phase 4: HTTP Header Inspection

HTTP response headers were inspected using cURL and OWASP ZAP to evaluate the implementation of standard security controls.

Phase 5: SSL/TLS Configuration Review

SSLScan was utilized to examine supported protocols, encryption standards, and cipher suite configurations.

4. Reconnaissance and Service Enumeration

4.1 Nmap Scan Results

The Nmap scan identified the following publicly exposed services:

Port	Protocol	State	Observation
80	HTTP	Open	Web application accessible
443	HTTPS	Open	Secure HTTPS service available
8080	HTTP-Proxy	Open	HTTP proxy service detected

4.2 Public Attack Surface Observations

- Both HTTP and HTTPS services are publicly accessible.
- Banking-related functionality is accessible without authentication.
- Application responses reveal information regarding underlying technologies and system structure.

5. Security Header Analysis

HTTP response headers were inspected using cURL and OWASP ZAP to evaluate security hardening mechanisms.

Security Header Findings

Security Header	Status	Observation
Content-Security-Policy	Missing	Increased exposure to XSS attacks
X-Frame-Options	Missing	Potential clickjacking risk
Strict-Transport-Security	Missing	Susceptible to downgrade attacks
X-Content-Type-Options	Missing	MIME sniffing possible
Server Header	Present	Information disclosure observed

The cURL inspection revealed the server is running Apache-Coyote/1.1, which is disclosed via the Server header. Additionally, session cookies were identified without the Secure flag, and the Strict-Transport-Security header was absent from responses.

6. SSL/TLS Configuration Review

SSLScan was used to assess protocol support and encryption configurations.

Protocol Assessment

Protocol	Status
TLS 1.2	Enabled
TLS 1.3	Disabled
SSLv2	Disabled
SSLv3	Disabled

Key Observations

- Deprecated SSL protocols (SSLv2, SSLv3) were disabled — a positive finding.
- TLS 1.2 support was enabled and operational.
- Cipher suite configurations require further security review.
- TLS 1.3 was not enabled, missing performance and security improvements.

7. OWASP ZAP Passive Analysis

OWASP ZAP passive scanning identified several security-related misconfigurations.

Passive Scan Findings

Finding	Risk Level
Content Security Policy Header Not Set	Medium
Missing Anti-Clickjacking Header	Medium
Cookie Without SameSite Attribute	Low
Information Disclosure Through Headers	Low
Missing X-Content-Type-Options Header	Low
Absence of Anti-CSRF Tokens	Medium
Strict-Transport-Security Header Not Set	Low
Information Disclosure – Debug Error Messages	Low
Information Disclosure – Suspicious Comments	Low
Session Management Response Identified	Informational

8. Detailed Vulnerability Findings

Finding 1: Missing Content Security Policy (CSP)

Attribute	Detail
Severity	Medium
OWASP Category	A05 – Security Misconfiguration
Description	The application does not implement a Content-Security-Policy (CSP) header, increasing the risk of Cross-Site Scripting (XSS) attacks.
Potential Impact	Attackers may inject and execute malicious scripts within user sessions.
Recommendation	Implement a restrictive Content-Security-Policy header to control trusted content sources.

Finding 2: Missing X-Frame-Options Header

Attribute	Detail
Severity	Medium
OWASP Category	A05 – Security Misconfiguration
Description	The application does not restrict iframe embedding, leaving users vulnerable to clickjacking attacks.
Potential Impact	Users may be tricked into performing unintended actions via maliciously crafted overlay pages.
Recommendation	Configure the X-Frame-Options header to DENY or SAMEORIGIN.

Finding 3: Cookie Without SameSite Attribute

Attribute	Detail
Severity	Low
OWASP Category	A07 – Identification and Authentication Failures
Description	Session cookies do not include the SameSite attribute.
Potential Impact	Potential exposure to Cross-Site Request Forgery (CSRF) attacks.
Recommendation	Configure cookies with SameSite=Strict or SameSite=Lax as appropriate for application functionality.

9. Risk Classification Matrix

Finding	Severity	OWASP Category
Missing CSP Header	Medium	A05 – Security Misconfiguration
Missing X-Frame-Options Header	Medium	A05 – Security Misconfiguration
Missing HSTS Header	Medium	A05 – Security Misconfiguration
Cookie Without SameSite Attribute	Low	A07 – Identification and Authentication Failures
Information Disclosure	Low	A05 – Security Misconfiguration

10. Security Posture Assessment

Security Evaluation Scores

Assessment Domain	Score
HTTP Security Headers	3 / 10
Cookie Security	4 / 10
SSL/TLS Configuration	6 / 10
Information Exposure	4 / 10
Client-Side Security	4 / 10

Overall Security Posture Score: 4 / 10 — MEDIUM RISK

The assessment identified multiple security misconfigurations that should be addressed before deployment within a production environment.

11. Remediation Recommendations

Priority 1 – Immediate Actions

- Implement missing HTTP security headers.
- Configure Content Security Policy (CSP).
- Configure X-Frame-Options protection.
- Remove unnecessary server banner disclosures.

Priority 2 – Short-Term Actions

- Configure Secure, HttpOnly, and SameSite cookie attributes.
- Enforce HTTPS across all application components.
- Implement HSTS headers.

Priority 3 – Medium-Term Actions

- Harden SSL/TLS configurations.
- Enable TLS 1.3 support where possible.
- Remove weak or deprecated cipher suites.

12. Conclusion

The passive vulnerability assessment of Altoro Mutual identified several security misconfigurations involving HTTP security headers, SSL/TLS configurations, cookie security settings, and information disclosure mechanisms.

The assessment was performed using strictly passive and non-intrusive techniques, ensuring that no exploitation attempts or destructive testing activities occurred.

The findings demonstrate common security weaknesses frequently encountered in web applications and provide valuable educational insight into secure application deployment and defensive security practices.

13. Disclaimer

This assessment was conducted solely for educational and internship purposes using passive and non-intrusive security testing techniques.

No exploitation attempts, unauthorized access, or destructive testing activities were performed during the assessment.

Altoro Mutual is an intentionally vulnerable web application designed for cybersecurity education and training.

This report is intended exclusively for educational demonstration, internship evaluation, academic submission, and professional portfolio purposes.